CYBER CRIMINALITÉ

WANNACRY SON HISTOIRE

RETOUR AUX ARTICLES

WANNACRY : UN « VER DE RANSOMWARE »

Qui est derrière ce ransomware ou « rançongiciel » responsable d'une véritable tempête dans le monde ? Entre le piratage de données confidentielles de la NSA, des failles dans les systèmes Windows non corrigées et les fantômes de la Corée du Nord..... Explications.

Avant de parler de Wannacry, il est peut être utile de préciser ce qu'est un "ransomware". Un ransomware ou « rançongiciel » est un type de malware qui bloque l'accès aux données de la victime et menace de publier, de revendre ou de supprimer ces données sauf si une rançon est payée. Les "ransomware" sont une des premières menaces rencontrées par les entreprises en France (plus d'information).

Wannacry appartient à cette famille et s'est rapidement répandu sur plusieurs réseaux informatiques en mai 2017. Après avoir infecté un ordinateur Windows, Wannacry cryptait les fichiers sur le disque dur du PC, les rendant inaccessibles aux utilisateurs, puis exigeait le paiement d'une rançon en Bitcoins en échange de la livraison d'une clé de décryptage.**WannaCry aurait fait plus de 300 000 victimes dans 150 pays.**

Plusieurs facteurs ont facilité la propagation rapide de ce ransonware :

- Il a frappé un certain nombre de systèmes importants, dont beaucoup au sein du National Health Service de Grande-Bretagne;
- Il a exploité une vulnérabilité de Windows qui était connue et sans doute déjà exploitée depuis plusieurs année par la National Security Agency américaine (NSA) à des fins d'espionnage ;

- D'après certains chercheurs en cyber sécurité (dont Symantec), WannaCry porterait la signature de l'organisation Lazarus, une organisation de cybercriminels qui pourraient être liés au gouvernement Nord-Coréen. En Septembre 2018, le **FBI accusait officiellement un citoyen Nord Coréen du nom de Park Jin Hyok** d'avoir été à l'origine du virus WannaCry ainsi que d'autres attaques informatiques. Selon la Corée du Nord, cette personne ces accusations ne sont que « pure diffamation. »

01 89 73 01 15

Comment fonctionne le ransomware WannaCry?

Le ransomware WannaCry se compose de plusieurs composants. Il arrive sur l'ordinateur infecté sous la forme d'un programme autonome qui extrait les autres composants de l'application intégrés en son sein. Ces composants comprennent:

- Une application qui chiffre et déchiffre les données
- Des fichiers contenant des clés de cryptage
- Une copie de Tor (un logiciel qui rend votre connexion anonyme)

Une fois lancé, WannaCry tente d'accéder à une URL codée en dur (le "kill switch"); s'il ne le peut pas, il procède au chiffrement des fichiers, en les laissant inaccessibles à l'utilisateur. Il affiche ensuite un avis de rançon, exigeant 300 $ en Bitcoin pour décrypter les fichiers.

Comment WannaCry infecte-t-il les PC?

Le vecteur d'attaque de WannaCry est plus intéressant que le ransomware lui-même. La vulnérabilité exploitée par WannaCry réside dans le protocole Server Message Block (SMB). On pense que la National Security Agency (NSA) a découvert cette vulnérabilité et, plutôt que de la signaler à la communauté, a développé un code pour l'exploiter, appelé **EternalBlue.** Cette information a été volée à la NSA par un groupe de cyber criminels connus sous le nom de Shadow Brokers, qui l'aurait publié dans un article le 8 avril 2017. Microsoft avait découvert la vulnérabilité un mois auparavant et avait publié un correctif qui malheureusement n'a pas été déployé partout.

Wannacry a exploité la faille EternalBlue pour infecter des ordinateurs, a commencé à se propager rapidement à partir du 12 mai 2017. Suite à cette épidémie, Microsoft a critiqué le gouvernement américain pour ne pas avoir communiqué plus tôt sa connaissance de la vulnérabilité.

Même si un ordinateur a été infecté avec succès, WannaCry ne commencera pas nécessairement à chiffrer les fichiers immédiatement. Wannacry tente d'abord d'accéder à une très longue URL absurde avant de se mettre au travail et de chiffrer les données. Si Wannacry peut accéder à ce domaine, WannaCry se ferme automatiquement. Le but de cette fonctionnalité n'est pas tout à fait clair, certains chercheurs en cyber sécurité pensant que cela était censé être un moyen pour les créateurs de ce logiciel malveillant de débrancher la cyber attaque.

Marcus Hutchins, chercheur en cyber sécurité d'origine britannique a découvert que WannaCry tentait de contacter cette URL absurde, a identifié dans le code en dur de Wannacry l'URL exacte sur laquelle pointait Wannacry, a déboursé 10,96 USD pour enregistrer le domaine et y créer un site, contribuant ainsi à empêcher la propagation du malware, sans toutefois l'arrêter. Peu de temps après avoir été salué comme un héros pour cela, Hutchins a été arrêté pour avoir prétendument développé différents logiciels malveillants en 2014. Il a proclamé son innocence.

Correctif / Patch WannaCry

Ironiquement, le correctif nécessaire pour prévenir les infections WannaCry était effectivement disponible avant le début de l'attaque ; Le Bulletin de sécurité Microsoft MS17-010, publié le 14 mars 2017, a mis à jour l'implémentation Windows du protocole SMB pour prévenir les infections via EternalBlue. Cependant, bien que Microsoft ait signalé le correctif comme critique, de nombreux systèmes n'étaient toujours pas corrigés en mai 2017, lorsque WannaCry a commencé à se répandre rapidement. Pour les systèmes infectés non corrigés, il n'y avait pas d'autre solution que de restaurer des fichiers à partir d'une sauvegarde.

Comme indiqué, Microsoft a publié un correctif pour la vulnérabilité SMB exploitée par WannaCry deux mois avant le début de l'attaque. Alors que les systèmes Windows 10 non corrigés étaient vulnérables, la fonctionnalité de mise à jour automatique intégrée au système d'exploitation signifiait que presque tous les systèmes Windows 10 étaient protégés en mai 2017.

Le correctif Microsoft SMB n'était initialement disponible que pour les versions de Windows courantes, ce qui excluait notamment Windows XP. Il existe encore des millions de systèmes Windows XP connectés à Internet - y compris au service national de santé britannique, où de nombreuses attaques de WannaCry ont été rapportées - et Microsoft a finalement rendu le correctif SMB disponible pour les anciennes versions du système d'exploitation.

Toutefois, il ne faut pas jeter la pierre aux entreprises qui n'ont pas été assez rapides pour mettre à jour leurs systèmes. Dans le monde professionnel, une mise à jour peut parfois coûter très cher. Sur des outils de production, une mise à jour, outre l'interruption qu'elle nécessite, peut impliquer de refaire certifier tout le système, entraînant des coûts pharaoniques pour chaque patch de sécurité. Chez les particuliers, effectuer une mise à jour peut aussi tourner au cauchemar, avec des logiciels tiers qui ne supportent pas les nouvelles moutures de Windows.

Le groupe Lazarus

Divers chercheurs en cyber sécurité ont essayé de comprendre les origines de WannaCry. Symantec pense que le code à l'origine de ce Ransomware pourrait avoir une origine nord-coréenne. Pour principaux éléments de preuve Symantec avance le fait que des versions antérieures du malware Wannacry baptisée Ransom.Wannacry a utilisé des identifiants volés pour lancer des attaques ciblées, présentant dans ces attaques des outils et techniques qui porteraient la signature du groupe Lazarus.
Le groupe Lazarus est quant à lui un groupe de cyber pirates lié à la Corée du Nord. Depuis leur début en 2009 avec des attaques DDoS brutales sur les ordinateurs du gouvernement sud-coréen, ils sont devenus de plus en plus sophistiqués, piratant Sony et réalisant des cambriolages de banques.
Cependant, il est impossible de savoir avec certitude si la vague initiale d'attaques WannaCry ou les dernières vagues d'attaques via EternalBlue ont été dirigées par la Corée du Nord, le code malveillant ayant été copié de manière généralisée par de nombreux groupes de cyber criminels.

01 89 73 01 15

WannaCry toujours actif, mais causant moins de dégâts

Malgré toute la publicité - sans parler des correctifs et des meilleures pratiques pour aider à le prévenir des attaques pa NOUS CHOISIR NOTRE OFFRE CULTURE CYBER OBTENEZ VOTRE DEVIS ars 2018, Boeing a été victime d'une attaque présumée de WannaCry. La société a déclaré que cela n'avait causé que peu de dommages, ne touchant que quelques machines de production. Boeing a pu arrêter l'attaque et restaurer rapidement les systèmes infectés. Boeing explique que cette attaque a été possible parce que le correctif n'avait pas été déployé sur l'ensemble des postes, ce qui explique pourquoi WannaCry peut encore faire des dégâts un an plus tard, notamment au sein de grandes organisations qui ne parviennent pas à déployer le correctif sur l'ensemble de leur parc informatique.Le danger le plus important aujourd'hui concerne les variantes de WannaCry, ou plus précisément, les nouveaux logiciels malveillants basés sur le même code EternalBlue que Wannacry, exploitant la même vulnérabilité Windows. L**e nombre d'attaques de ce type a augmenté en 2018 vs 2017, suggérant que de nombreux systèmes Windows non corrigés soient toujours disponibles**. Il n'est plus qu'une question de temps avant qu'un attaquant les trouve.

Marc-Henri BOYDRON

REVENIR AUX ARTICLES

Nos articles focus

Qu'est-ce que la cyberassurance ? A quoi sert un contrat de cyberassurance ? Qu'est-ce que le phishing ?

CYBER CRIMINALITÉ
Bilan 2025 : Cyberattaques en France – Stratégie d'assurance cyber

CYBER SÉCURITÉ
Fin de Windows 10 : quels impacts sur votre assurance cyber ?

ASSURANCE
CSIRT et assurance cyber : doublon ou complémentarité ?

TOUS NOS ARTICLES

NOS OFFRES CYBER ASSURANCE

Assurance cyber

01 89 73 01 15